

Checkov Security Scan Report - TrueTally

Checkov Security Scan Report - TrueTally Terraform

Error Detectado: CKV2_AWS_46

Política: Ensure AWS CloudFront Distribution with S3 have Origin Access set to enabled

Severidad: MEDIUM

Descripción: Cuando CloudFront está conectado a un origen S3, debe usarse Origin Access Identity (OAI) para evitar que el bucket sea accesible públicamente. Sin OAI, cualquier usuario puede acceder directamente al bucket S3 si las políticas lo permiten.

Antes (Código con fallo)

```
resource "aws_cloudfront_distribution" "frontend" {
  # ... omitted for brevity ...

  origin {
    domain_name = aws_s3_bucket.frontend.bucket_regional_domain_name
    origin_id   = "s3-origin"
    # FALTA s3_origin_config con OAI
  }
}
```

Resultado Checkov: FAILED

Solución Implementada

Se agregaron 3 recursos:

1. Origin Access Identity

```
resource "aws_cloudfront_origin_access_identity" "frontend" {
  comment = "OAI for ${local.name_prefix} frontend"
}
```

2. Bucket Policy (permite acceso solo al OAI)

```
resource "aws_s3_bucket_policy" "frontend" {
  bucket = aws_s3_bucket.frontend.id
  policy = jsonencode({
    Version = "2012-10-17"
    Statement = [{
      Sid      = "AllowCloudFrontAccess"
      Effect   = "Allow"
      Principal = { AWS = aws_cloudfront_origin_access_identity.frontend.iam_arn }
      Action   = "s3:GetObject"
      Resource  = "${aws_s3_bucket.frontend.arn}/*"
    }]
  })
}
```

```
}
```

3. Actualización del CloudFront Distribution

```
origin {
  domain_name = aws_s3_bucket.frontend.bucket_regional_domain_name
  origin_id   = "s3-origin"

  s3_origin_config {
    origin_access_identity = "origin-access-identity/cloudfront/${aws_cloudfront_origin_access_identity.frontend.id}"
  }
}
```

Después (Código corregido)

Resultado Checkov: PASSED

Integración CI/CD

Checkov se integró en `.github/workflows/terraform.yml` como `job security` que: - Corre antes del `plan` `job` - Usa la acción oficial `bridgecrewio/checkov-action@master` - Falla el pipeline (`soft_fail: false`) si hay problemas de seguridad - Sube resultados como `artifact XML`

```
jobs:
  security:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
      - uses: bridgecrewio/checkov-action@master
        with:
          directory: terraform
          soft_fail: false
```

Beneficios de la solución

- El bucket S3 solo es accesible a través de CloudFront (no directamente)
- Política de seguridad en profundidad (defensa en capas)
- Cumple con estándares de compliance AWS
- Protege contra acceso no autorizado a contenido estático
- Escaneo automático de seguridad en cada commit/PR